

Especificação Completa da API

- **Projeto:** Sistema de Gestão de Vendas e Caixa
 - **Versão da API:** v1
 - **Base URL:** <https://api.dominio.com.br/api/v1/>
 - **Formato:** JSON ([Content-Type: application/json](#))
 - **Transporte:** HTTPS obrigatório (RNF01)
 - **Documento anterior:** [especificacao_sistema_vendas_v2.md](#)
 - **Documento seguinte recomendado:** Fluxo de sincronização offline (documento técnico 7)
-

1. Convenções gerais

1.1 Autenticação

Todas as rotas, exceto `POST /auth/terminal/` e `POST /auth/login/`, exigem cabeçalho:

```
Authorization: Bearer <token>
```

Existem **dois níveis de identidade** por requisição, refletindo o modelo do M10 Pro (RF01, nota do Diagrama de Casos de Uso):

Nível	O que autentica	Como é obtido
Terminal	O dispositivo M10 Pro físico	<code>POST /auth/terminal/</code> com a senha do terminal
Vendedor/Operador	A pessoa selecionada no terminal	<code>POST /auth/select-user/</code> (sem senha, apenas seleção)

O `terminal_token` identifica loja + terminal. O `session_token` (retornado após seleção de vendedor) é o que efetivamente autoriza operações de venda e carrega `loja + terminal + vendedor` em cada requisição subsequente — consistente com a regra “toda venda registra loja + terminal + vendedor”.

Para perfis Dono, Gerente e Caixa (que usam credencial própria, diferente do vendedor no M10), a autenticação é feita via `POST /auth/login/` (usuário/senha tradicional), retornando um `access_token` JWT.

1.2 Cabeçalhos obrigatórios

Cabeçalho	Obrigatório	Descrição
<code>Authorization</code>	Sim (exceto login)	Bearer token
<code>X-Store-Id</code>	Sim para operações de loja	Loja à qual a operação pertence
<code>X-Device-Id</code>	Sim para operações do M10	Identificador do terminal físico (RF30 — dispositivo)
<code>X-Idempotency-Key</code>	Sim para métodos POST que criam recurso	UUID v4 gerado pelo cliente (RF36)
<code>X-Client-Timestamp</code>	Recomendado	Timestamp local do evento, para reconciliação offline

1.3 Paginação

Listagens usam paginação por cursor:

```
GET /sales/?page_size=20&cursor=eyJ...
```

```
{
  "results": [ ... ],
  "next_cursor": "eyJ...",
  "previous_cursor": null,
  "count": 134
}
```

1.4 Formato de erro padrão

```
{
  "error": {
    "code": "PERMISSION_DENIED",
    "message": "Usuário não possui perfil autorizado para esta operação.",
    "details": {}
  }
}
```

HTTP status	Código	Uso
400	VALIDATION_ERROR	Corpo da requisição inválido
401	UNAUTHENTICATED	Token ausente/expirado
403	PERMISSION_DENIED	Perfil sem permissão (RF02, RNF02)
404	NOT_FOUND	Recurso inexistente
409	CONFLICT	Estado inconsistente (ex.: venda já confirmada)
409	SYNC_CONFLICT	Conflito de sincronização (13.11)
422	INVALID_STATE_TRANSITION	Transição de estado não permitida
429	RATE_LIMITED	Excesso de requisições
500	INTERNAL_ERROR	Erro não tratado

1.5 Idempotência (RF36, RNF04)

Toda rota de criação/mutação relevante (vendas, pagamentos, sincronização) exige `X-Idempotency-Key`. O servidor armazena o par (chave, resposta) por 24h; uma repetição da mesma chave retorna a resposta original com status `200` e cabeçalho `X-Idempotent-Replay: true`, sem reprocessar.

1.6 Controle de acesso (RF02, RNF02)

Toda permissão é validada no backend, nunca apenas na interface. As tabelas de permissão por endpoint estão na seção 4.

Perfis: `DONO`, `GERENTE`, `VENDEDOR`, `CAIXA`. Um usuário pode acumular perfis (ex.: Dono que também opera caixa).

2. Autenticação e sessão

2.1 POST /auth/terminal/

Autentica o dispositivo M10 Pro pela senha do terminal (não vinculada a um vendedor específico).

Request

```
{ "store_id": 1, "terminal_password": "*****" }
```

Response 200

```
{
  "terminal_token": "eyJhbGciOi...",
  "terminal_id": 7,
  "store_id": 1,
  "expires_in": 43200
}
```

2.2 GET /auth/terminal/sellers/

Lista os vendedores habilitados a operar no terminal (para exibição da tela de seleção — sem senha).

Auth: `terminal_token`

```
{ "results": [ { "id": 12, "name": "João Silva" }, { "id": 15, "name": "Maria Costa" } ] }
```

2.3 POST /auth/select-seller/

Seleção do vendedor no terminal — sem credencial, conforme regra de negócio (“a seleção não concede permissões administrativas”).

Auth: `terminal_token`

```
{ "seller_id": 12 }
```

Response 200

```
{
  "session_token": "eyJhbGciOi...",
  "seller_id": 12,
  "store_id": 1,
  "terminal_id": 7,
  "role": "VENDEDOR",
  "expires_in": 28800
}
```

2.4 POST /auth/login/

Login tradicional para Dono, Gerente e Caixa (RF01).

```
{ "username": "gerente.loja1", "password": "*****" }
```

```
{ "access_token": "...", "refresh_token": "...", "role": "GERENTE", "store_ids": [1, 2], "expires_in": 3600 }
```

2.5 POST /auth/refresh/

```
{ "refresh_token": "..." }
```

2.6 `POST /auth/logout/`

Invalida o token atual. Gera evento de auditoria (RF29 — login/logout).

3. Recursos

3.1 Usuários, perfis e lojas

Método	Rota	Descrição	Quem pode
GET	/users/	Lista usuários	Dono
POST	/users/	Cria usuário	Dono
GET	/users/{id}/	Detalhe	Dono, próprio usuário
PATCH	/users/{id}/	Atualiza dados/perfil	Dono
DELETE	/users/{id}/	Desativa (nunca exclui — RF31)	Dono
GET	/roles/	Lista perfis disponíveis	Dono
GET	/stores/	Lista lojas	Todos autenticados
POST	/stores/	Cria loja	Dono
PATCH	/stores/{id}/	Atualiza loja	Dono
GET	/terminals/	Lista terminais por loja	Dono, Gerente
POST	/terminals/	Cadastra terminal M10 e define senha	Dono
PATCH	/terminals/{id}/	Redefine senha do terminal / vendedores habilitados	Dono, Gerente

Exemplo — `POST /users/`

```
{
  "name": "Maria Costa",
  "username": "maria.vendedora",
  "password": "****",
  "roles": ["VENDEDOR"],
  "store_ids": [1]
}
```

3.2 Produtos (RF04)

Método	Rota	Descrição	Quem pode
GET	/products/	Lista produtos (suporta <code>?q=</code> , <code>?category=</code>)	Todos autenticados
GET	/products/{id}/	Detalhe	Todos autenticados
POST	/products/	Cria produto	Dono, Gerente
PATCH	/products/{id}/	Atualiza	Dono, Gerente
DELETE	/products/{id}/	Inativa (sem exclusão física)	Dono, Gerente
GET	/product-categories/	Lista categorias (Peças, Pneus, Óleos, + futuras)	Todos autenticados
POST	/product-categories/	Cria categoria	Dono

Sem controle de estoque: o cadastro contém apenas identificação, preço e categoria (para fins de comissão).

```
{
  "name": "Pneu Aro 15",
  "sku": "PNEU-A15-001",
  "price": "500.00",
  "category": "PNEUS"
}
```

3.3 Clientes (RF05)

Método	Rota	Descrição	Quem pode
GET	/customers/	Lista/busca clientes (?q=)	Vendedor, Caixa, Gerente, Dono
POST	/customers/	Cadastra cliente	Vendedor, Caixa, Gerente, Dono
GET	/customers/{id}/	Detalhe	Vendedor, Caixa, Gerente, Dono
PATCH	/customers/{id}/	Atualiza	Gerente, Dono
GET	/customers/{id}/receivables/	Pendências do cliente (RF15)	Vendedor, Caixa, Gerente, Dono

GET /customers/{id}/receivables/

```
{
  "results": [
    {
      "id": 501,
      "sale_id": 10482,
      "original_amount": "1500.00",
      "paid_amount": "0.00",
      "pending_amount": "1500.00",
      "status": "ABERTA",
      "created_at": "2026-08-05T14:32:00Z"
    }
  ]
}
```

3.4 Vendas (RF06-RF12, RF13-RF14)

3.4.1 POST /sales/

Criação da venda pelo vendedor. Requer `session_token` (vendedor autenticado no terminal).

Auth: Vendedor

Idempotência: obrigatória

```
{
  "customer_id": 42,
  "payment_method": "PIX",
  "items": [
    { "product_id": 10, "quantity": 2, "unit_price": "250.00", "discount": "0.00" },
    { "product_id": 33, "quantity": 1, "unit_price": "1000.00", "discount": "0.00" }
  ]
}
```

Regras aplicadas no backend: - Um único vendedor responsável (RF06) — vem da sessão, não do payload. - Se `payment_method == "NOTINHA"`, `customer_id` é obrigatório (RF14) e a venda não pode ser criada sem cliente vinculado. - Percentual de comissão de cada item é **calculado e congelado no momento da criação** (RF19, RF20), usando a regra vigente na data/hora da venda. - Desconto já embutido no valor do item; comissão calculada sobre o valor líquido (13.3).

Response 201

```

{
  "id": 10482,
  "store_id": 1,
  "terminal_id": 7,
  "seller_id": 12,
  "status": "AGUARDANDO_CAIXA",
  "barcode": "SALE-10482-7F3A",
  "total_amount": "1500.00",
  "payment_method": "PIX",
  "customer_id": 42,
  "items": [
    { "id": 1, "product_id": 10, "quantity": 2, "unit_price": "250.00", "line_total": "500.00", "commission_perce
    "3.00", "commission_amount": "15.00" },
    { "id": 2, "product_id": 33, "quantity": 1, "unit_price": "1000.00", "line_total": "1000.00",
    "commission_percent": "5.00", "commission_amount": "50.00" }
  ],
  "created_at": "2026-08-05T14:32:00Z"
}

```

3.4.2 Estados da venda

AGUARDANDO_CAIXA → PAGA → (opcional) CANCELADA / DEVOLVIDA_PARCIAL / DEVOLVIDA_TOTAL
 AGUARDANDO_CAIXA → EM_ALTERACAO → AGUARDANDO_CAIXA (aprovada) | AGUARDANDO_CAIXA (rejeitada, sem mudança)

Modelo de estados completo da venda deve ser formalizado no “Modelo de estados da venda” (documento técnico 3), análogo ao já existente para a notinha.

3.4.3 Demais rotas de venda

Método	Rota	Descrição	Quem pode
GET	/sales/{id}/	Detalhe da venda	Vendedor da venda, Caixa, Gerente, Dono
GET	/sales/	Lista (?status=, ?store_id=, ?seller_id=, ?date_from=, ?date_to=)	Gerente, Dono; Vendedor vê apenas as próprias; Caixa vê AGUARDANDO_CAIXA / PAGA
GET	/sales/by-barcode/{barcode}/	Localiza venda pelo código de barras (RF09)	Caixa
POST	/sales/{id}/document-1/print/	Reimpressão do documento 1 (auditável)	Vendedor, Gerente, Dono
POST	/sales/{id}/change-request/	Solicita alteração (RF24)	Vendedor
POST	/sales/{id}/change-request/{req_id}/decide/	Aprova/rejeita (RF25)	Gerente, Dono
POST	/sales/{id}/cancel/	Cancela venda (RF26)	Gerente, Dono
POST	/sales/{id}/return/	Autoriza devolução (RF27)	Gerente, Dono

POST /sales/{id}/change-request/

```

{ "requested_changes": { "items": [ { "id": 2, "quantity": 2 } ] }, "reason": "Cliente pediu mais uma unidade" }

```

Retorna 201 com status: "PENDENTE".

POST /sales/{id}/change-request/{req_id}/decide/

```

{ "decision": "APROVADA", "note": "Confirmado com o cliente" }

```

decision: APROVADA | REJEITADA. Gera auditoria em ambos os casos (RF25).

POST /sales/{id}/cancel/

```
{ "reason": "Erro de lançamento" }
```

`reason` obrigatório (RF26). Backend nega se solicitante não for Dono/Gerente (`403 PERMISSION_DENIED` , CA08). Estorna comissão dos itens (RF28) e gera auditoria.

POST `/sales/{id}/return/` Exige referência ao documento 2 (13.4) e, opcionalmente, itens específicos para devolução parcial (13.5).

```
{
  "document_2_reference": "DOC2-10482-9K1",
  "items": [ { "sale_item_id": 1, "quantity": 1 } ],
  "reason": "Produto com defeito"
}
```

Sem `document_2_reference` válida → `422 INVALID_STATE_TRANSITION`.

3.5 Caixa e pagamento (RF09-RF12)

Método	Rota	Descrição	Quem pode
GET	<code>/cash/pending-sales/</code>	Vendas aguardando caixa na loja	Caixa
POST	<code>/cash/payments/</code>	Confirma recebimento (RF10, RF11)	Caixa
POST	<code>/sales/{id}/document-2/print/</code>	Imprime documento 2 após confirmação (RF12)	Caixa

POST `/cash/payments/`

Idempotência: obrigatória

```
{
  "sale_id": 10482,
  "payment_method": "PIX"
}
```

Regras: `payment_method` deve ser um dos habilitados (RF10); sem pagamento dividido; se a venda já tiver `payment_method = NOTINHA` definido na criação, esta rota não se aplica — usar `/receivables/{id}/payments/`. Ao confirmar, `status` → `PAGA`, comissão dos itens muda para `LIBERADA` (RF21), e o documento 2 passa a poder ser emitido.

Response 200

```
{
  "sale_id": 10482,
  "status": "PAGA",
  "paid_at": "2026-08-05T14:41:00Z",
  "cashier_id": 30,
  "document_2_available": true
}
```

3.6 Notinha e pendências (RF13-RF16, 13.1)

Método	Rota	Descrição	Quem pode
GET	<code>/receivables/</code>	Lista pendências (<code>?customer_id=</code> , <code>?status=</code> , <code>?store_id=</code>)	Caixa, Gerente, Dono, Vendedor (próprias vendas)
GET	<code>/receivables/{id}/</code>	Detalhe	idem
POST	<code>/receivables/{id}/payments/</code>	Registra quitação integral (13.1)	Caixa

POST `/receivables/{id}/payments/`

Idempotência: obrigatória

```
{ "payment_method": "DINHEIRO" }
```

Regra de negócio: não aceita `amount` parcial — a API sempre quita o valor total pendente em uma única operação. Envio de valor divergente do saldo devedor → `422 VALIDATION_ERROR`. Ao confirmar: `status` → `QUITADA`, comissão dos itens da venda original `RETIDA` → `LIBERADA` (RF22, modelo de comissão seção B).

Response 200

```
{
  "receivable_id": 501,
  "status": "QUITADA",
  "paid_amount": "1500.00",
  "paid_at": "2026-08-10T09:00:00Z",
  "cashier_id": 30
}
```

3.7 Comissão (RF17-RF23)

Todas as rotas abaixo são restritas ao perfil **Dono** (RF18, RNF03) — o backend deve retornar `403` para qualquer outro perfil, mesmo que a rota seja acessada diretamente.

Método	Rota	Descrição
GET	<code>/commission-rules/</code>	Lista a matriz vendedor x categoria vigente
POST	<code>/commission-rules/</code>	Cria/atualiza percentual (gera nova versão vigente + auditoria — RF32)
GET	<code>/commission-rules/history/</code>	Histórico de alterações (RF18 — “histórico das alterações”)
GET	<code>/commissions/</code>	Consulta comissão por item/venda (<code>?sale_id=</code> , <code>?seller_id=</code>)
GET	<code>/commissions/report/</code>	Relatório por período/vendedor/categoria (RF23)
POST	<code>/commissions/{item_id}/adjust/</code>	Ajuste/estorno manual (RF28, casos excepcionais)

POST `/commission-rules/`

```
{ "seller_id": 12, "category": "PNEUS", "percent": "4.00", "effective_from": "2026-08-10T00:00:00Z" }
```

Não sobrescreve vendas já registradas (RF20) — apenas define a regra aplicável a vendas **futuras**.

GET `/commissions/report?date_from=2026-08-01&date_to=2026-08-31&seller_id=12`

```
{
  "seller_id": 12,
  "period": { "from": "2026-08-01", "to": "2026-08-31" },
  "by_category": [
    { "category": "PECAS", "sales_total": "20000.00", "commission_total": "1000.00" },
    { "category": "PNEUS", "sales_total": "15000.00", "commission_total": "450.00" },
    { "category": "OLEOS", "sales_total": "5000.00", "commission_total": "200.00" }
  ],
  "grand_total_commission": "1650.00"
}
```

POST `/commissions/{item_id}/adjust/`

```
{ "new_amount": "0.00", "reason": "Estorno por cancelamento da venda 10482" }
```

Gera novo registro (nunca sobrescreve o anterior — RF31/seção B do modelo de comissão), com auditoria completa.

3.8 Auditoria (RF29-RF32)

Método	Rota	Descrição	Quem pode
GET	/audit-logs/	Consulta (?entity=, ?entity_id=, ?user_id=, ?date_from=, ?date_to=, ?action=)	Dono; Gerente com escopo limitado (sem eventos de comissão)
GET	/audit-logs/{id}/	Detalhe de um evento	idem

Registros são **somente leitura via API** — não existe `PATCH` / `DELETE` (RF31). Toda correção gera novo registro operacional + novo evento de auditoria.

```
{
  "id": "aud_9f31...",
  "timestamp": "2026-08-10T09:32:00Z",
  "user_id": 1,
  "role": "DONO",
  "store_id": 1,
  "action": "ALTERACAO_COMISSAO",
  "entity": "CommissionRule",
  "entity_id": 88,
  "before": { "percent": "3.00" },
  "after": { "percent": "4.00" },
  "reason": null,
  "device_id": null,
  "ip": "200.100.1.1",
  "operation_id": "op_7788..."
}
```

3.9 Sincronização offline (RF33-RF37, 13.9-13.11)

Método	Rota	Descrição	Quem pode
POST	/sync/push/	Envia lote de operações pendentes do dispositivo	Vendedor/Caixa (via terminal)
GET	/sync/pull/	Baixa dados de referência (produtos, clientes, regras aplicáveis) para cache local	Terminal
GET	/sync/conflicts/	Lista conflitos pendentes de decisão	Gerente, Dono
POST	/sync/conflicts/{id}/resolve/	Resolve conflito	Gerente, Dono

`POST /sync/push/`

```
{
  "operations": [
    {
      "operation_id": "op-uuid-001",
      "type": "SALE_CREATE",
      "payload": { "...": "corpo equivalente ao POST /sales/" },
      "occurred_at": "2026-08-10T18:02:00Z"
    },
    {
      "operation_id": "op-uuid-002",
      "type": "CASH_PAYMENT",
      "payload": { "...": "corpo equivalente ao POST /cash/payments/" },
      "occurred_at": "2026-08-10T18:05:00Z"
    }
  ]
}
```

Cada `operation_id` é único e idempotente (RF36) — reenviar a mesma operação nunca a duplica. Operações **não permitidas offline** (cancelamento, devolução, alteração de regra de comissão, gestão de usuários/permissões — 13.9) são rejeitadas com `403 PERMISSION_DENIED` mesmo dentro de um lote de sync, e não interrompem o processamento das demais operações do lote.

Response 200

```
{
  "results": [
    { "operation_id": "op-uuid-001", "status": "SINCRONIZADO", "server_id": 10490 },
    { "operation_id": "op-uuid-002", "status": "CONFLITANTE", "conflict_id": "cf-uuid-1" }
  ]
}
```

Estados por operação: `SINCRONIZADO`, `ERRO_SINCRONIZACAO`, `CONFLITANTE` (13.9). O servidor é sempre a fonte de verdade (13.11) — nunca há resolução automática por “última alteração vence”.

`POST /sync/conflicts/{id}/resolve/`

```
{ "resolution": "MANTER_SERVIDOR", "note": "Dados do terminal desatualizados" }
```

`resolution`: `MANTER_SERVIDOR` | `APLICAR_OPERACAO_LOCAL` | `MESCLAR` (quando aplicável). Gera auditoria obrigatoriamente (13.11).

4. Matriz de autorização por endpoint (resumo)

Recurso/Ação	Vendedor	Caixa	Gerente	Dono
Criar venda	✓	-	✓*	✓*
Confirmar pagamento	-	✓	✓*	✓*
Criar notinha	✓	-	✓*	✓*
Quitar notinha	-	✓	✓*	✓*
Solicitar alteração	✓	-	✓	✓
Aprovar/rejeitar alteração	-	-	✓	✓
Cancelar venda	-	-	✓	✓
Autorizar devolução	-	-	✓	✓
Ver percentual/valor de comissão	-	-	-	✓
Definir regra de comissão	-	-	-	✓
Relatório de comissão	-	-	-	✓
Ajustar/estornar comissão	-	-	-	✓
Gerenciar usuários/perfis/lojas	-	-	-	✓
Consultar auditoria completa	-	-	parcial**	✓
Resolver conflito de sincronização	-	-	✓	✓

* Gerente/Dono podem operar como vendedor/caixa apenas se estiverem fisicamente autenticados no terminal correspondente. ** Gerente não acessa eventos de auditoria relacionados a comissão (RF18).

Toda linha desta matriz deve ser implementada como verificação de permissão no backend (RNF02) — nunca apenas ocultando botões na interface Flutter.

5. Campos sensíveis e serialização condicional

Para os perfis `GERENTE`, `VENDEDOR` e `CAIXA`, os seguintes campos **nunca** devem aparecer no corpo da resposta JSON (não apenas ocultos na UI — removidos na serialização do backend, RF18/RNF03):

- `commission_percent`
- `commission_amount`
- Qualquer agregação de `/commissions/*`

Exemplo: o mesmo `GET /sales/{id}/` retorna payloads diferentes conforme o perfil do requisitante:

```
// resposta para DONO
{ "id": 1, "product_id": 10, "line_total": "500.00", "commission_percent": "3.00", "commission_amount": "15.00"
```

```
// resposta para VENDEDOR/CAIXA/GERENTE
{ "id": 1, "product_id": 10, "line_total": "500.00" }
```

6. Convenções de estado (referência cruzada)

Entidade	Estados	Documento de origem
Venda	AGUARDANDO_CAIXA , PAGA , EM_ALTERACAO , CANCELADA , DEVOLVIDA_PARCIAL , DEVOLVIDA_TOTAL	Modelo de estados da venda (a formalizar)
Notinha/Pendência	ABERTA , EM_RECEBIMENTO , EM_ALTERACAO , QUITADA , CANCELADA , BAIXADA_DEVOLUCAO , VENCIDA (futuro)	Modelo de Estados da Notinha
Comissão do item	CALCULADA , RETIDA , LIBERADA , ESTORNADA/AJUSTADA	Modelo de Comissão
Operação de sync	PENDENTE_SINCRONIZACAO , SINCRONIZADO , ERRO_SINCRONIZACAO , CONFLITANTE	Especificação v2, 13.9

7. Itens em aberto para próxima revisão

- Formalizar o **Modelo de estados da venda** como documento próprio (hoje inferido a partir das regras de negócio), incluindo transições de `EM_ALTERACAO`.
- Definir o schema definitivo de `requested_changes` em `change-request` (hoje genérico, chave-valor).
- Definir paginação/streaming para `/sync/pull/` em lojas com grande volume histórico.
- Especificar formato exato de payload aceito pelo SDK do M10 Pro para impressão (documentos 1 e 2) e leitura de código de barras — depende de definição em “Especificação de integração com o M10 Pro”.
- Confirmar se `X-Device-Id` deve ser validado contra uma lista de terminais cadastrados (proposto, ainda não é RF explícito).